

CONSTRUCTION OS

PRD - Complete Role & Permission Matrix

Implementation-ready Product Requirements Document for Product, Enterprise Architecture, Backend, Frontend, Security, QA, DevOps, SRE and Company Governance Teams

Product purpose

Define the authoritative, deny-by-default authorization model for every internal, external, mobile, support and automated identity across ConstructionOS.

Document: PRD_Complete_Role_Permission_Matrix

Version: 1.0

Status: Implementation-ready platform authorization specification

Platform scope: All companies, groups, projects, modules, portals, devices and service identities

Core model: Capability-based RBAC + contextual ABAC + relationship-based access + field policy + SoD

Date: 2026-08-06

ConstructionOS Confidential

Document Control

Field	Value
Document	PRD_Complete_Role_Permission_Matrix
Version	1.0
Status	Implementation-ready functional and technical specification
Primary owner	ConstructionOS Product and Security Architecture
Audience	Product, architecture, backend, frontend, security, QA, DevOps, SRE and governance teams
Primary policy	Deny by default; explicit capability plus authorized scope
Decision model	RBAC + ABAC + ReBAC + field policy + SoD + temporary authority
Source-of-truth	Authorization owns role, capability, grant, deny, delegation and decision policy records
Platform Configuration	Mandatory at role, capability, scope, field, delegation, device and review level
Date	2026-08-06

Permanent authorization rule

No role name, employment title, project membership or administrator label grants business authority by itself. Every protected action requires an explicit capability and an authorized context.

Table of Contents

1. Executive Summary
2. Product Vision and Business Outcomes
3. Success Metrics and Guardrails
4. Scope, Non-Goals and Assumptions
5. Terminology and Core Concepts
6. Permanent Authorization Principles
7. Authorization Decision Model
8. Access Dimensions and Scope Hierarchy
9. Permission Action Taxonomy
10. Capability Catalogue and Naming Standard
11. Permission Precedence and Explicit Deny
12. Governance Hierarchy
13. Platform Administration Roles
14. Company Owner and Company Admin
15. Group and Shared-Service Roles
16. Executive, Department and Team Roles
17. Project Role Architecture
18. Record-Relationship Roles
19. Finance Role Matrix
20. Procurement and Supplier Roles
21. Contracts, Legal and Compliance Roles
22. HR, Payroll and Workforce Roles

23. QA/QC, HSE, Inventory and Assets Roles
 24. Documents, BIM, Progress, CRM and Analytics Roles
 25. Workflow Roles and Separation of Duties
 26. Delegation, Temporary Access and Substitutes
 27. Impersonation, Support and Break-Glass Access
 28. Client and Supplier Portal Roles
 29. Mobile, Offline, Device and Channel Policy
 30. Field-Level and Record-Level Security
 31. Joint Venture and Active-Company Access
 32. Permission Requests, Role Templates and Inheritance
 33. Authorization Data Model
 34. Backend Services and Evaluation Flow
 35. Caching, Revocation and Propagation
 36. Search, Export, Bulk Actions and Reauthentication
 37. Access Reviews and Identity Lifecycle
 38. Service Accounts and Automated Identities
 39. Audit, Administration and Diagnostics
 40. Platform Configuration
 41. Baseline Governance Matrix
 42. Module Authority Matrix
 43. API and Event Contracts
 44. Security and Privacy Requirements
 45. Non-Functional Requirements
 46. Testing Strategy and Critical Scenarios
 47. Acceptance Criteria
 48. Delivery Phases and Rollout
 49. Migration and Adoption Strategy
 50. Risks and Open Decisions
 51. Definition of Done
- Appendix A - Capability Examples
- Appendix B - Standard Role Catalogue

1. Executive Summary

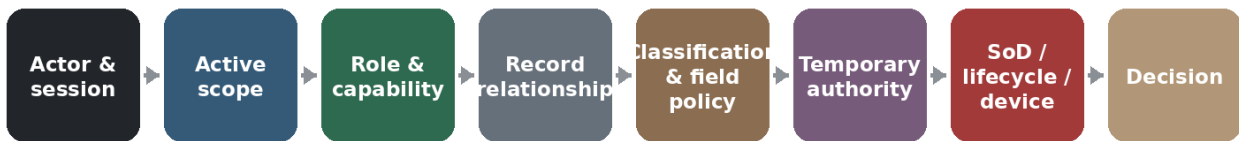
ConstructionOS requires one authorization model that remains consistent across internal workspaces, corporate groups, companies, projects, Joint Ventures, external portals, mobile devices, workflow approvals, support sessions and automated services. Without a consolidated matrix, modules would interpret roles differently, confidential fields could leak through APIs or search, and administrator labels could become unintended business authority.

This PRD defines the complete role and permission architecture. It uses capability-based roles for reusable authority, contextual policies for tenant/company/project and record scope, relationship rules for assignment-based access, field policies for restricted values, explicit denial, effective-dated temporary authority, separation of duties, device controls and immutable authorization audit.

Final product position

Platform Admin operates the SaaS platform. Company Owner governs the company. Company Admin operates the company. Business and project roles govern assigned domains. External users see only relationship-based published projections.

Authorization Decision Model



Output

- ALLOW / DENY / CONDITIONAL
- Reason code and matched grants
- Effective scope and field policy
- Reauthentication / workflow conditions
- Policy version and audit context

2. Product Vision and Business Outcomes

- Provide one explainable authorization result for every protected query, command, export, approval and administrative action.
- Prevent cross-tenant, cross-company, cross-project and confidential-data leakage at the backend query boundary.
- Allow one person to hold different roles in different companies and projects without creating duplicate accounts.
- Protect Company Owner authority while allowing broad Company Admin operations.
- Keep Platform Admin outside customer operations unless an approved support or emergency session exists.
- Support practical delegation, temporary coverage and Joint Venture collaboration without permanent over-permissioning.
- Ensure portal and mobile users receive minimized, expiring and revocable access.
- Make every allow, deny, field restriction, delegation and exceptional access decision auditable.

3. Success Metrics and Guardrails

Metric	Initial target	Guardrail
Unauthorized cross-tenant access	0 confirmed incidents	Automated isolation suite blocks release
Sensitive-field leakage	0 restricted fields in unauthorized	Backend projection filtering, not UI masking

Metric	Initial target	Guardrail
	API/search/export responses	
Authorization decision latency	p95 <= 75 ms for cached common decisions	High-risk decisions may require live evaluation
Revocation propagation	API immediate; derived surfaces <= 60 seconds	Mobile offline expiry and sync revalidation
Role explainability	100% of protected actions return reason code	No hidden role-name shortcut
High-risk audit coverage	100% of privileged actions	Immutable actor, scope and policy version
Access review completion	>= 98% by due date	Unreviewed temporary grants expire
Support-session overrun	0 sessions active after expiry	Automatic termination and token invalidation

4. Scope, Non-Goals and Assumptions

4.1 In scope

- Internal and external role templates
- Capability catalogue
- Tenant/group/company/project/record scopes
- Field-level security
- Direct grants and explicit denies
- Delegation and temporary access
- Impersonation, support and break-glass sessions
- Workflow eligibility and separation of duties
- Mobile/device-aware authorization
- Portal relationship-based access
- Permission decisions, audit and diagnostics
- Access reviews and lifecycle automation

4.2 Non-goals

- Replacing business-state validation in source modules
- Treating job titles as universal authority
- Allowing Platform Admin routine access to tenant operations
- Using UI visibility as a security control
- Granting external users internal employee identities
- Implementing legal e-signature equivalence through permissions alone
- Allowing role customization to create Owner or platform authority

4.3 Assumptions

- Tenant is the technical isolation boundary and Company is the operational ownership boundary.
- A user may hold several company, group, department, team and project assignments.
- Module PRDs remain authoritative for business-state transitions.
- The Workflow Engine owns routing and exact approval participation.
- Source modules enforce the final authorization result.

5. Terminology and Core Concepts

Term	Definition
Principal	Human user, external membership, team or service account receiving authority.
Capability	Atomic permission to perform one action on one resource type.

Term	Definition
Role	Versioned collection of capabilities with allowed scope types.
Scope	Tenant, group, company, project, record or other boundary in which authority applies.
Grant	Explicit allow assignment to a principal.
Deny	Explicit restriction that overrides ordinary grants.
Field policy	VISIBLE, REDACTED, MASKED, SUMMARY_ONLY, HIDDEN, EDITABLE or READ_ONLY behavior.
Relationship access	Authority derived from an explicit relation such as assignee, owner, inspector or client contact.
SoD	Separation-of-duty rule blocking incompatible authorities or self-approval.
Permission snapshot	Recorded authorization context used for a high-risk action.
Active company	Explicit company context used for navigation, search and authorization.
Break-glass	Exceptional, time-limited emergency access with immediate oversight.

6. Permanent Authorization Principles

ID	Principle	Required behavior
RAP-P01	Deny by default	Absence of a valid grant results in denial.
RAP-P02	Backend enforcement	Restricted data is excluded from source queries and projections.
RAP-P03	Explicit active scope	The backend never guesses the active company.
RAP-P04	No title shortcuts	Employment title or role label alone is insufficient.
RAP-P05	Owner protection	Company Admin cannot modify, impersonate or remove Company Owner.
RAP-P06	Platform separation	Platform administrators do not receive routine tenant business access.
RAP-P07	Exact workflow authority	Module authority does not automatically make a user an approver.
RAP-P08	Versioned policy	Roles, capabilities and policies are versioned and auditable.
RAP-P09	Revocable derived access	Search, Portal, Mobile and file access must follow current authority.
RAP-P10	Explainability	Every protected action can be explained with matched policy and reason code.

7. Authorization Decision Model

The decision engine evaluates identity, current scope, capability, record context, data classification, temporary authority, device/channel controls and business restrictions. It returns ALLOW, DENY or CONDITIONAL together with the field policy and any required reauthentication or workflow condition.

Input	Examples
Actor	User ID, external membership, service account, employment state
Authentication	Session age, MFA, impersonation, device trust
Company scope	Tenant, active company, parent/child, JV scope
Resource	Domain, entity type, record ID, owner and status
Relationship	Project member, assignee, owner, reviewer, inspector
Temporary authority	Delegation, support access, standing coverage
Requested action	View, edit, approve, export, impersonate, override
Restrictions	Explicit deny, field policy, SoD, legal hold, offline rule

8. Access Dimensions and Scope Hierarchy

Layer	Purpose	Examples
Platform	SaaS operation	Plans, tenant provisioning, system health
Tenant	Technical isolation	One customer environment
Business group	Related-company governance	Parent and selected subsidiaries
Company	Legal and operational ownership	Company A
Department / Team	Organizational scope	Finance, Architecture Team
Project	Project participation	Project X
Location / Work package	Field execution scope	Tower B, MEP package
Module / Record type	Functional boundary	Finance, Contract
Record / Field	Fine-grained control	Legal case 14, salary field
Time / Device / Channel	Context control	Temporary grant, managed mobile, online-only

9. Permission Action Taxonomy

Action family	Standard actions
Discovery and read	discover, list, view_summary, view, view_sensitive, view_history, view_audit, download
Creation and maintenance	create, edit_draft, edit, edit_sensitive, submit, withdraw, return, reopen, archive, restore
Controlled lifecycle	verify, approve, reject, issue, publish, activate, post, certify, close, lock, reverse, adjust, override

Action family	Standard actions
Collaboration	comment, mention, assign, reassign, delegate, request_information, upload_evidence, share_internal, share_external
Data operations	export, import, bulk_edit, bulk_assign, print, generate_report, view_analytics
Administration	configure, manage_templates, manage_roles, manage_permissions, manage_users, manage_devices, manage_workflows
Exceptional authority	impersonate, support_access, break_glass, emergency_override, permanent_delete, transfer_ownership

10. Capability Catalogue and Naming Standard

Capability keys use <domain>.<resource>.<action>. Every definition declares risk, allowed scopes, delegation policy, reauthentication, SoD conflicts, audit requirements and channel availability.

Capability example	Meaning	Risk
projects.project.view	View authorized Project record	Standard
documents.revision.publish	Publish controlled Document Revision	High
finance.journal.post	Post balanced Journal Entry	Critical
finance.payment.approve	Approve Payment Instruction	Critical
quality.inspection.accept	Record final quality acceptance	High
hse.stop_work.release	Release active stop-work restriction	Critical
hr.compensation.view	View restricted compensation fields	High
workflow.definition.manage	Manage workflow definitions	High
platform.company.delete_execute	Execute approved tenant deletion	Critical

11. Permission Precedence and Explicit Deny

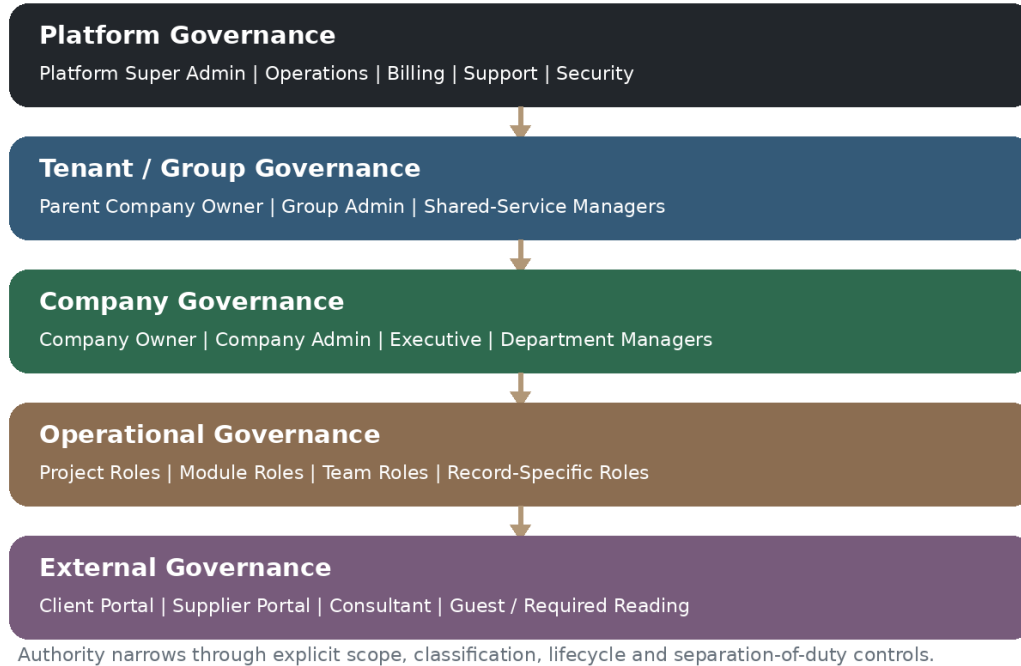
1. Tenant suspension or deletion standby
2. Security lock or account suspension
3. Legal or compliance restriction
4. Explicit record/user deny
5. Separation-of-duty prohibition
6. Data-classification restriction
7. Device/channel restriction
8. Temporary-context limits
9. Explicit capability grant
10. Role-derived grant
11. Default deny

Explicit deny

Explicit deny overrides ordinary role grants. It may be used to exclude a group user from a child company, restrict a confidential matter or block a specific field/action.

12. Governance Hierarchy

Governance and Authority Layers



13. Platform Administration Roles

Role	Primary responsibilities	Tenant business-data access
Platform Super Admin	Platform administrators, global security, plans, emergency platform controls	None by default
Company Operations Admin	Company applications, verification, suspension, deletion workflow	None by default
Application Reviewer	Public professional, contractor and company application reviews	Submitted application data only
Billing Admin	Plans, subscriptions, invoices, usage and entitlements	Billing metadata only
Support Admin	Approved support cases and scoped support sessions	Only within active approved session
Security / SRE Admin	Infrastructure health, redacted logs, backups and security operations	No routine business access
Data Protection / Audit Reviewer	Platform privacy, audit and access-review evidence	Metadata and authorized audit scope

13.1 Platform Super Admin restrictions

- May not browse customer Projects, Finance, HR, Legal, Contracts or Documents by default.
- May not impersonate Company Owner.
- May not approve tenant business transactions.
- Emergency access requires a break-glass case and post-event review.

14. Company Owner and Company Admin

Capability	Company Owner	Company Admin
All company modules and sensitive records	Full	Full
Create/edit/approve/archive/restore ordinary records	Full	Full, subject to workflow/SoD
Manage ordinary users and roles	Full	Full
Create/remove/change Company Admin	Exclusive	Prohibited
Impersonate ordinary employee	Allowed by policy	Allowed by policy
Impersonate Company Owner	Not applicable	Prohibited
Manage subscription and support approval	Exclusive	Prohibited
Transfer ownership	Exclusive	Prohibited
Request company deletion	Exclusive	Prohibited
Alter or permanently delete audit	Prohibited	Prohibited

Workflow eligibility

Company Admin is broadly approval-capable, but the Workflow Engine determines eligibility for the exact step, source version, value threshold and separation-of-duty policy.

15. Group and Shared-Service Roles

Role	Default authority	Constraints
Parent Company Owner	Full group and child-company business authority	Audit, immutable records and platform controls remain enforced
Group Admin	Delegated group governance	Explicit child-company restrictions apply
Group Finance Manager	Group Finance consolidation and selected operations	Company/field policies and active scope
Group Legal Manager	Selected legal matters across group	Matter-level confidentiality
Group HR Manager	Group workforce and HR policy	Payroll/medical restrictions
Group Procurement Manager	Shared supplier and procurement governance	Company-specific commercial confidentiality
Group BIM / QA / HSE Manager	Shared professional governance	Project and record scopes

16. Executive, Department and Team Roles

Role	Baseline access	Default exclusions
Executive / CEO	Executive dashboards, project/company summaries, assigned high-value approvals	Payroll lines, medical data, unassigned privileged legal matters
Department Manager	Department users, records, budgets, tasks and approvals	Other departments and unrelated confidential data

Role	Baseline access	Default exclusions
Team Manager	Team membership, assignments and workload	Company-wide configuration and unrelated projects
Team Member	Shared team records and assigned operational actions	Managerial and sensitive authorities

17. Project Role Architecture

Project assignments must carry project, company, project role, location/work-package scope, effective dates, financial visibility and confidentiality restrictions.

Project role	Primary authority
Project Director	Executive project governance and high-level decisions
Project Manager	Day-to-day project control and assigned project approvals
Site / Construction Manager	Site execution, packages, logistics and coordination
Project Controls / Planner	Schedule, progress and performance
Commercial / Cost Controller	Project commercial and cost views
Design / BIM Manager	Design coordination, model and federation governance
QA/QC Manager / Inspector	Quality planning, assigned inspections and acceptance
HSE Manager / Officer	Project safety governance and execution
Document Controller	Project documents, transmittals and publication
Procurement Lead / Storekeeper	Project purchasing and warehouse operations
Site Engineer / Foreman	Assigned technical field execution
Consultant / Reviewer	Restricted review and decision participation
Observer	Read-only project scope

18. Record-Relationship Roles

Relationship	Typical authority
creator	Maintain draft and withdraw before controlled review
requester	View own submission, answer information requests, resubmit
record_owner	Manage record within module capability
assignee	Execute and update assigned work
reviewer	Record review outcome for assigned stage
approver	Decide assigned workflow work item
project_manager	Project-scoped management and review
contract_owner	Manage contract draft and obligations
budget_owner	Review budget-consuming requests

Relationship	Typical authority
document_controller	Publish within assigned project/company
inspector / investigator	Perform assigned inspection or investigation
custodian	View and operate assigned asset
client / supplier contact	External relationship-based actions

19. Finance Role Matrix

Role	Key capabilities	Critical restrictions
Finance Director	Full Finance, periods, budgets, approvals, reports	SoD and immutable posting rules
Finance Manager / Chief Accountant	Accounting management and approvals	Cannot silently alter posted entries
Accountant	Prepare journals and invoices	Cannot approve own journal by default
Accounts Payable	Supplier invoices, matching, payment proposals	No payment execution without authority
Accounts Receivable	Client invoices, receipts and collections	No unrelated supplier financial data
Treasury	Banking and payment execution	Approved instructions only
Cashier	Controlled cash transactions	Limited accounts and values
Budget Manager	Budget and forecast management	No journal posting unless separately granted
Cost Controller	Project cost views and analysis	No company-wide payroll detail
Finance Auditor	Read, audit and export under policy	No operational edits

20. Procurement and Supplier Roles

Role	Key capabilities	Restrictions
Procurement Director / Manager	Supplier governance, requisitions, RFQs, evaluations, awards, approved PO issue	Cannot replace Finance, Inventory or Contracts ownership
Buyer	Sourcing, clarifications, comparison, recommendations and PO preparation	Cannot approve own award where SoD applies
Procurement Analyst	Read and analyse procurement performance	No confidential action authority
Supplier Qualification Manager	Qualification, categories and compliance	No payment or stock authority
Tender Committee Member	Assigned technical/commercial evaluation	Cannot view data outside assigned process
Receiving Coordinator	Delivery expectations and coordination	Inventory posts physical receipt
Procurement Auditor	Read and audit procurement records	No edits

21. Contracts, Legal and Compliance Roles

Role group	Typical capabilities	Restrictions
Contracts Director / Manager	Contract drafting, revisions, obligations,	Legal and commercial approvals remain separately

Role group	Typical capabilities	Restrictions
	amendments and issuance	assignable
Contract Administrator	Draft maintenance, notices and obligation follow-up	No final legal authority by default
General Counsel / Legal Manager	Privileged matters, legal review, settlement and notices	Matter-level access and reauthentication
Legal Counsel / External Counsel	Assigned matters and documents	No unrelated tenant records
Compliance / Permit Manager	Permits, obligations, submissions and regulatory deadlines	No privileged legal opinion unless granted
Legal Auditor	Read legal/compliance evidence	No operational edits

22. HR, Payroll and Workforce Roles

Role	Key capabilities	Sensitive restrictions
HR Director / Manager	Employee lifecycle, positions, leave and HR governance	Medical/payroll fields separately controlled
HR Officer / People Operations	Operational HR records and onboarding	No payroll or private case access by default
Recruiter	Candidates, offers and operational fitness outcome	No restricted medical or payroll data
Payroll Manager / Specialist	Compensation, payroll runs, adjustments and payslips	SoD for final approval and Finance posting
Attendance Officer	Attendance and shift events	No salary or payroll calculation
Training Manager	Training, qualifications and eligibility	No unrelated private HR data
Line Manager	Direct-report leave, timesheets and operational summaries	No salary, medical or disciplinary data
Employee Self-Service	Own profile, leave, timesheet, payslip and training	Own records only
HR Auditor	Restricted read and audit	No edits

23. QA/QC, HSE, Inventory and Assets Roles

Domain	Role templates	Important controls
QA/QC	Quality Director, QA/QC Manager, Inspector, Commissioning Manager, Handover Manager, Auditor	Finding, acceptance, corrective work and handover are separate authorities
HSE	HSE Director, Manager, Officer, Incident Investigator, Permit Issuer, Emergency Coordinator, Auditor	Medical, witness and investigation data restricted; stop-work release separate
Inventory	Inventory Manager, Warehouse Manager, Storekeeper, Stock Controller, Receiving Officer, Auditor	Adjustment approval separate; valuation remains Finance
Assets	Asset Manager, Fleet Manager, Maintenance Manager, Technician, Custodian, Operator, Auditor	Scope by project, location, asset class and custody

24. Documents, BIM, Progress, CRM and Analytics Roles

Domain	Role templates	Key separation
Documents	Governance Manager, Controller, Author, Reviewer, Approver, Publisher, Records Manager	Upload, review, approval and issue are separate
BIM / Digital Twin	BIM Director, Manager, Coordinator, Author, Reviewer, Federation Manager, Viewer	Model access does not grant linked operational-record access
Work Progress	Planning Manager, Planner, Progress Engineer, Site Reporter, Verifier, Certifier	Submit, verify, accept, certify and pay remain separate
CRM / Sales	Sales Director, Manager, Agent, CRM Manager, Unit Sales, Reservation Officer	Buyer identity, discount and payment fields require explicit authority
Reporting	Viewer, Author, Metric Owner, Data Steward, Analytics Admin, Auditor	Permission before aggregation; sharing does not grant data

25. Workflow Roles and Separation of Duties

Workflow role	Authority
Workflow Administrator	Manage runtime, failures and configuration; not automatically an approver
Workflow Designer	Create and simulate drafts
Workflow Publisher	Publish validated workflow versions
Approval Matrix Manager	Manage routing thresholds
Approver / Reviewer	Act only on assigned work item and exact source version
Delegation Manager	Manage delegated decision authority under policy
Workflow Auditor	Read definitions, instances and decision evidence
Emergency Override Reviewer	Perform independent post-event review

25.1 Required SoD examples

- Create Journal != Approve Journal
- Prepare Payment != Approve Payment
- Calculate Payroll != Sole Final Payroll Approval
- Create Supplier != Approve Supplier Bank Change
- Prepare Award != Sole Award Approval
- Draft Contract != Final Legal Approval
- Inspect Work != Execute Corrective Work
- Request Stock Adjustment != Approve Adjustment
- Request Company Deletion != Execute Platform Deletion
- Emergency Override != Sole Post-Event Review

26. Delegation, Temporary Access and Substitutes

Field	Requirement
Delegator and delegate	Both identities preserved
Capability subset	No implicit full-role delegation

Field	Requirement
Scope	Company, project, record or workflow
Maximum value	Required for financial/commercial authority
Effective dates	Mandatory start and expiry
Reason	Mandatory and audited
Re-delegation	Disabled by default
Sensitive exclusions	Configurable non-delegable classes
Automatic revocation	At expiry, leaver event or authority loss

Recommended non-delegable authorities

Ownership transfer, company deletion request, platform deletion execution, Company Owner impersonation, audit deletion, encryption-key access and Platform Super Admin assignment.

27. Impersonation, Support and Break-Glass Access

27.1 Impersonation

Company Admin may impersonate ordinary employee accounts where enabled. Every action records the actual Admin and effective employee identity. Company Owner impersonation is prohibited.

27.2 Support session

State	Required control
Requested	Defined issue, company and requested scope
Owner Approved	Authorized approver and time limit
Active	Persistent banner, scoped modules/records/actions
Expiring	Warnings and token expiry
Ended	Immediate revocation and final audit
Reviewed	Outcome and any data-access review

27.3 Break-glass

- Strong reauthentication
- Mandatory reason
- Minimal scope and time
- Real-time alert to security and Owner
- Complete sensitive-access audit
- Automatic expiry
- Independent post-event review

28. Client and Supplier Portal Roles

Portal	Role templates
Client	Organization Admin, Executive, Project Representative, Buyer/Unit Owner, Reviewer, Handover Representative, Finance Viewer, Defect Reporter, Read-Only
Supplier	Organization Admin, Commercial Manager, Estimator, Delivery Coordinator, Technical Submitter, Invoice Submitter, HSE Representative, QA/QC Representative, Read-Only

- Portal access is relationship-based and effective-dated.
- Portal Organization Admin may manage members only inside the organization and existing access relationships.
- External actions create immutable submissions, requests or acknowledgements.
- Supplier users cannot view competing quotations, internal notes or unrelated Projects.
- Internal company authority controls new business-access relationships.

29. Mobile, Offline, Device and Channel Policy

Mobile authorization requires user capability, scope, registered device, device security state, offline workspace grant, expiry and sync-time revalidation.

Action category	Offline policy
View authorized projections	Allowed within workspace scope and expiry
Create draft / evidence	Allowed for supported commands
Post Finance / execute payment	Online only
Issue Contract / publish controlled record	Online only
Formal final approval	Server-confirmed online only
Change permissions	Online only
Emergency report	May capture offline; UI must distinguish local-recorded from server-received
Revocation	Blocks new sync and removes/invalidates restricted workspace

30. Field-Level and Record-Level Security

Policy	Behavior
VISIBLE	Returned and displayed
REDACTED	Returned only as approved redacted value
MASKED	Partially concealed value
SUMMARY_ONLY	Derived non-sensitive summary only
HIDDEN	Not queried or returned
EDITABLE	May be changed under capability and lifecycle rules
READ_ONLY	Visible but never editable in current context

Domain	Common protected field groups
Finance	Bank account, unit price, margin, payment proof, tax, budget, cash position
HR / Payroll	Salary, bank data, identifiers, medical, disciplinary and private notes
Legal	Privileged opinion, litigation strategy, witness and settlement authority
Procurement	Competing quotations, evaluation notes, negotiation limits, bank changes
HSE	Medical detail, witness statements and investigation analysis
CRM / Units	Buyer identity, discount, payment status and personal contacts

31. Joint Venture and Active-Company Access

JV visibility value	Meaning
PRIVATE_TO_OWNER_COMPANY	Only the owning company and explicitly assigned users
SHARED_WITH_ALL_JV_PARTNERS	All companies in the active JV scope
SHARED_WITH_SELECTED_COMPANIES	Listed JV companies only
SHARED_WITH_SELECTED_USERS	Named users only

Active-company rule

The session must carry an explicit active_company_id or group scope. Switching scope refreshes permissions, navigation, dashboards, search, notifications, saved views and mobile workspace availability.

32. Permission Requests, Role Templates and Inheritance

32.1 Permission requests

1. Requested
2. Manager review
3. Data owner review
4. Security/compliance review when required
5. Approved or rejected
6. Grant activated
7. Expired or revoked

32.2 Role templates

- System templates are versioned and upgrade-aware.
- Company custom roles may combine approved capabilities.
- Custom roles cannot create Owner-equivalent or platform authority.
- Role cloning creates a new ID and capability snapshot.

32.3 Inheritance

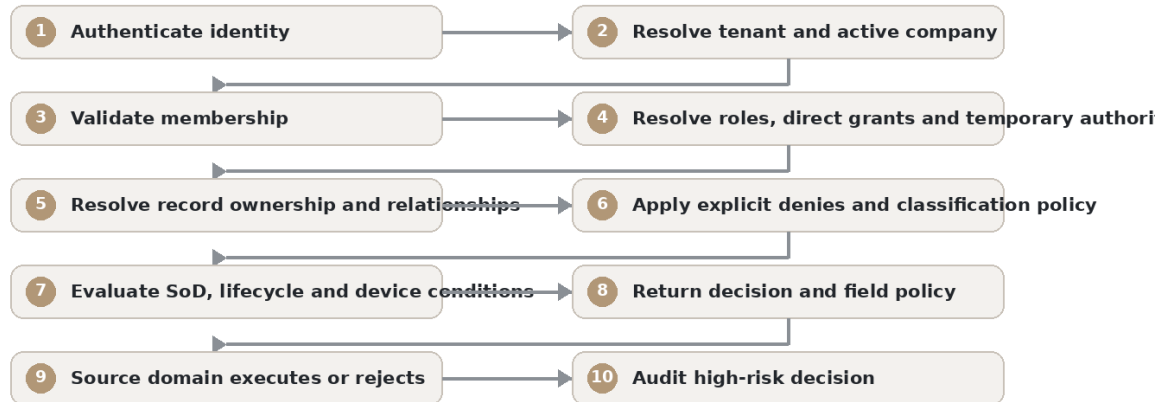
Direct user grants, role assignments, department/team roles, project roles, group shared-service roles and temporary delegations are combined, then constrained by active scope, explicit deny, record ownership, classification, SoD, device policy and lifecycle state.

33. Authorization Data Model

Entity	Primary responsibility
RoleDefinition	Logical role identity and owner
RoleVersion	Immutable role revision
CapabilityDefinition	Atomic action definition and risk metadata
RoleCapability	Role-to-capability mapping
PrincipalRoleAssignment	Effective-dated role assignment and scope
AccessGrant	Direct allow authority
AccessDeny	Explicit deny override
ScopeDefinition	Named scope and hierarchy
ScopeMembership	Principal relationship to scope
FieldPolicy	Field visibility and edit behavior
DataClassificationPolicy	Classification rules
RelationshipPolicy	Record relationship access
SeparationOfDutyRule	Incompatible authority rules
DelegationGrant	Delegated authority
TemporaryAccessGrant	Time-limited access
ImpersonationSession	Actual/effective actor session
SupportSession	Approved platform support access
BreakGlassSession	Emergency privileged access
PermissionRequest	Access request and review
PermissionDecision	Evaluated allow/deny/conditional result
PermissionDecisionReason	Explainability reason
PermissionSnapshot	High-risk action context
AuthorizationPolicyVersion	Published policy baseline

34. Backend Services and Evaluation Flow

Permission Evaluation Flow



Service	Responsibility
Authorization Policy Service	Evaluate final permission policy
Capability Registry	Manage capability definitions and versions
Role Management Service	Roles and assignments
Scope Resolution Service	Tenant/company/project/record scope
Relationship Resolver	Owner, assignee, manager and participant relationships
Field Policy Service	Field-level projection decisions
SoD Service	Incompatible authority evaluation
Delegation Service	Temporary and delegated authority
Permission Cache	Low-latency reusable decisions
Revocation Service	Invalidate sessions, caches and projections
Access Review Service	Periodic certification
Authorization Audit Service	Immutable policy-change and decision audit

35. Caching, Revocation and Propagation

Cache key component	Purpose
user_id	Principal identity

Cache key component	Purpose
tenant_id	Technical boundary
active_company_id	Operational context
policy_version	Published policy revision
membership_version	Company/group membership state
role_assignment_version	Role changes
delegation_version	Temporary authority state
security_version	Session/account/device revocation

- Invalidate on role, membership, project, delegation, confidentiality, device, support-session or policy change.
- High-risk decisions may require live evaluation.
- Revocation must propagate to API, search, portal, mobile, files and generated projections.

36. Search, Export, Bulk Actions and Reauthentication

36.1 Search

- Permission scope applied before scoring and counts.
- Restricted fields excluded from index.
- Opening a result rechecks source access.
- Locked-result discovery is configurable and never exposes sensitive content.

36.2 Export

- Export is a separate capability from view.
- Policy controls rows, fields, watermark, classification, expiry and sharing.
- Restricted exports require audit and may require reauthentication.

36.3 Bulk actions

- Separate bulk capability
- Preview and scope confirmation
- Validation and error manifest
- Idempotency
- Optional workflow approval

36.4 Reauthentication

Recommended for ownership transfer, company deletion, support approval, payment execution, payroll finalization, bank-detail change, legal settlement, emergency override, impersonation, restricted export and role escalation.

37. Access Reviews and Identity Lifecycle

Process	Required behavior
Access review	Retain, modify, revoke, expire or escalate high-risk access
Joiner	Account, membership, approved role, project scope and device activation
Mover	Review old grants, assign new role and recalculate scope

Process	Required behavior
Leaver	Disable login, revoke sessions/devices/delegations and reassign records
Dormant account	Automatic suspension or review according to policy
Temporary grant	Automatic expiry if not renewed

Important boundary

HR onboarding readiness may trigger access work, but checklist completion never silently grants platform permissions.

38. Service Accounts and Automated Identities

Field	Requirement
Identity	Distinct from human users
Owner	Named service and responsible team
Purpose	Single documented integration purpose
Capabilities	Minimum API-specific subset
Environment	Production/test separated
Credentials	Rotated, non-human and securely stored
Expiry	Mandatory where possible
Network	Allowlisted where applicable
UI login	Prohibited
Owner/Admin roles	Prohibited
Cross-tenant authority	Explicit and narrowly controlled

39. Audit, Administration and Diagnostics

39.1 Mandatory audit events

- Role/capability creation and versioning
- Assignments, grants, denies and expiry
- Delegation and temporary access
- Impersonation, support and break-glass sessions
- Permission requests and reviews
- Sensitive field reads and restricted exports
- Permission denials and override attempts
- Device revocation and propagation

39.2 Administration pages

- Roles
- Role Templates
- Capability Catalogue
- User Access

- Team Access
- Project Access
- External Access
- Direct Grants
- Explicit Denials
- Delegations
- Temporary Access
- Permission Requests
- Impersonation Sessions
- Support Sessions
- Break-Glass Cases
- SoD Rules
- Field Policies
- Access Reviews
- Permission Audit
- Authorization Diagnostics

39.3 Diagnostics questions

- Why can this user view the record?
- Why is this field hidden?
- Which role or grant supplied authority?
- Which deny blocked the action?
- Which policy version was evaluated?
- When does access expire?

40. Platform Configuration

- Available system and custom roles
- Direct grant and explicit deny policy
- Delegation limits and maximum period
- Impersonation, support and break-glass policy
- Reauthentication interval
- Access-request routing
- Locked-search-result behavior
- Field classifications and export controls
- Mobile and portal authority
- Access-review frequency
- Default role mappings
- SoD rules and retention

41. Baseline Governance Matrix

Role	Company data	Users/roles	Sensitive data	Approvals	Impersonation	Owner actions
Platform Super Admin	None	Platform only	None	None	Owner prohibited	None
Support Admin	Approved scope	None	Approved scope	None	None	None
Parent Company Owner	Full group	Full	Full	Full/assigned	Employees	Full
Company Owner	Full company	Full	Full	Full/assigned	Employees	Full
Group Admin	Scoped	Scoped	Scoped	Assigned	Policy-based	Prohibited
Company Admin	Full company	Ordinary users	Full	Full/assigned	Employees	Prohibited
Executive/CEO	Read/scoped	None	Scoped	Assigned	None	Prohibited
Department Manager	Department	Team scoped	Restricted	Assigned	None	Prohibited
Project Manager	Project	Project scoped	Restricted	Assigned	None	Prohibited
Ordinary User	Assigned	None	Restricted	Assigned only	None	Prohibited
Portal Org Admin	External relationship	Own organization	Projection only	External actions	None	Prohibited
Guest	Assigned record	None	None	Acknowledge	None	Prohibited

42. Module Authority Matrix

Module	Primary management roles	Sensitive restrictions
Projects	Owner, Admin, Project Director, Project Manager	Cross-company and confidential projects
Units	Owner, Admin, Sales/Unit Manager	Buyer, price and payment data
Tasks	Assigned users, managers and project roles	Source-record restrictions
Documents	Controllers, authors, reviewers, publishers	Exact revision and classification
CRM	Sales and CRM roles	Client personal and financial data
Contracts	Contracts and Legal roles	Commercial and privileged terms
Finance	Finance roles	Banking, payments, journals and budgets
Procurement	Procurement roles	Competing quotations, evaluation and bank changes
Inventory	Warehouse and Inventory roles	Valuation and adjustments
Assets	Asset/Fleet roles	Custody, cost and location
Work Progress	Progress and Project Controls roles	Commercial certification
QA/QC	Quality roles	Acceptance and client sign-off
HSE	HSE roles	Medical and investigation data
Legal	Legal roles	Matter-level privilege
HR / Payroll	HR and Payroll roles	Employment, salary, banking and medical
Calendar	Users and scheduling roles	Private event detail
BIM	BIM roles	Confidential layers and linked records
Reporting	Viewers, authors and data roles	Permission before aggregation
Workflow	Designers, admins and assigned approvers	No automatic business authority
Mobile / Portals	Operational/external roles	Scope, expiry and publication only

43. API and Event Contracts

43.1 Core authorization APIs

Method and route	Purpose
POST /authorization/decisions	Evaluate one protected action
POST /authorization/decisions/batch	Evaluate list or page actions
GET /authorization/capabilities	Capability catalogue
GET /authorization/roles	Role definitions and versions
POST /authorization/assignments	Create role assignment
POST /authorization/grants	Create direct grant
POST /authorization/denials	Create explicit deny
POST /authorization/delegations	Create delegated authority
POST /authorization/permission-requests	Request access
GET /authorization/diagnostics	Explain effective access
POST /authorization/revocations	Force revocation propagation

43.2 Published events

- authorization.role_published
- authorization.assignment_created
- authorization.assignment_revoked
- authorization.grant_created
- authorization.deny_created
- authorization.delegation_activated
- authorization.delegation_expired
- authorization.policy_published
- authorization.permission_request_approved
- authorization.support_session_started
- authorization.support_session_ended
- authorization.device_access_revoked

44. Security and Privacy Requirements

ID	Area	Requirement	Priority	Acceptance signal
RAP-SEC-001	Default deny	Every protected query and command denies without a valid effective grant.	Must	Automated negative tests pass
RAP-SEC-002	Tenant isolation	All supplied record IDs are verified against tenant and active scope.	Must	Cross-tenant ID attack fails
RAP-SEC-003	Field security	Restricted fields are excluded from APIs, indexes and exports.	Must	Payload tests show no hidden data
RAP-SEC-004	Owner protection	Company Admin cannot modify or impersonate Owner.	Must	All Owner attack scenarios denied
RAP-SEC-005	Support access	Support access is approved, scoped, time-limited and	Must	Expired session loses access

ID	Area	Requirement	Priority	Acceptance signal
		visible.		
RAP-SEC-006	SoD	Configured incompatible capabilities block the action.	Must	Self-approval tests fail safely
RAP-SEC-007	Revocation	Revocation invalidates sessions, caches and derived access.	Must	Propagation SLA met
RAP-SEC-008	Audit	Privileged and sensitive actions create immutable audit events.	Must	Complete event evidence

45. Non-Functional Requirements

Area	Requirement
Performance	Cached common decision p95 <= 75 ms; batch decisions used for lists
Availability	Authorization core target >= 99.95% for enterprise; fail closed for protected actions
Scalability	Thousands of concurrent users and high-volume list authorization
Consistency	Role and revocation events propagate deterministically
Resilience	No grant on timeout; retry-safe administrative commands
Observability	Decision latency, deny rate, cache hit, revocation lag and policy errors
Accessibility	Administration and request workflows meet WCAG target
Localization	Role and reason labels localized; capability keys remain stable
Privacy	Diagnostic and audit output minimizes confidential record data
Recovery	Roles, grants, policies and audit included in tested backups

46. Testing Strategy and Critical Scenarios

- Company Admin attempts to impersonate Company Owner.
- Platform Admin opens Finance without a Support Session.
- Group user switches to an unauthorized child company.
- Project Manager queries another Project using a known ID.
- Recruiter requests restricted medical data.
- Manager exports salary through a report.
- User with view access attempts raw export.
- Accountant attempts to approve own journal.
- Buyer attempts to approve own award.
- Portal Admin grants access to another Project.
- Supplier attempts to infer competing quotation data.
- Mobile user loses Project access while offline.
- Delegation exceeds financial limit.
- Support Session expires during an open page.
- Role changes while a cached token remains active.
- Workflow approver loses company membership.
- Company enters deletion standby.
- Explicit deny conflicts with broad Group role.
- Search reveals restricted record counts.
- Impersonated session attempts ownership transfer.
- Service account attempts UI login.
- Break-glass used without review.
- Legal hold blocks deletion-capable Admin.
- Portal publication remains after relationship revocation.
- Revocation removes search, portal, mobile and file access.

47. Acceptance Criteria

AC-001: Deny-by-default authorization is enforced in every source domain.

AC-002: Tenant and active-company scope are explicit and visible.

AC-003: One user may hold different roles in different companies.

AC-004: Company Owner protections are enforced.

AC-005: Company Admin receives broad operations but no Owner-only authority.

AC-006: Platform Admin receives no routine business-data access.

AC-007: Support access is approved, scoped, time-limited and audited.

AC-008: Impersonation preserves actual and effective actor identity.

AC-009: Group roles do not silently expose child-company records.

AC-010: JV sharing is record-configurable.

AC-011: Module entry and exact-record authority are evaluated separately.

AC-012: Field-level security shapes backend responses.

AC-013: Workflow participation is distinct from module authority.

AC-014: SoD rules block incompatible actions.

AC-015: Delegations are scoped, effective-dated and auditable.

AC-016: Portal access is relationship-based.

AC-017: Mobile permissions are revalidated on sync.

AC-018: Revocation propagates to sessions, search, caches, files and projections.

AC-019: Role templates and policy versions are preserved.

AC-020: Diagnostics explain every allow or deny.

AC-021: Critical isolation and confidentiality tests pass.

48. Delivery Phases and Rollout

Phase	Scope	Exit criteria
1 - Foundation	Capability catalogue, roles, active company, deny-by-default, audit, Owner/Admin governance	Core protected APIs use central decision contract
2 - Operational scoping	Department/team/project roles, record relationships, field policy, search and export	Major modules pass scoped access tests
3 - Advanced governance	Delegation, temporary access, explicit deny, SoD, reauthentication, impersonation, support	High-risk workflows certified
4 - External and mobile	Portal roles, device policy, offline workspace access and revocation	External/mobile isolation tests pass
5 - Assurance	Access reviews, diagnostics, break-glass, service accounts and permission analytics	Operational runbooks and certification complete

49. Migration and Adoption Strategy

1. Inventory current module-specific roles and permission checks.
2. Map existing roles to capability keys without increasing authority.
3. Introduce active-company context before group-wide role expansion.
4. Run legacy and new decisions in comparison mode for selected actions.
5. Migrate high-risk modules first: Identity, Finance, HR/Payroll, Legal, Documents and Workflow.
6. Backfill effective-dated assignments and explicit ownership scope.
7. Train Company Owners and Admins using diagnostics and access-review workflows.
8. Remove legacy shortcuts only after parity and negative-security testing.

50. Risks and Open Decisions

Topic	Decision required / risk
Owner breadth	Confirm whether Owner may be field-restricted by company-created policy or only by platform/legal controls.

Topic	Decision required / risk
Company Admin approval	Define default workflow eligibility versus broad approval capability.
Locked search results	Confirm which record types may show minimal locked metadata.
Group restrictions	Confirm child-company authority to deny Parent shared-service roles.
Portal organization admin	Define invitation and removal limits.
Offline retention	Set maximum cache duration by data classification.
Impersonation	Confirm sensitive actions that require return to direct Admin context.
Break-glass	Define required reviewers and SLA.
Custom roles	Define capabilities prohibited from all custom roles.
Access review cadence	Set default frequency by risk class.
Policy engine technology	Confirm embedded policy runtime versus dedicated service.
Field masking	Define jurisdiction-specific masking rules for identifiers and bank data.

51. Definition of Done

- All Must requirements and acceptance criteria are implemented and tested.
- Every module has mapped capability keys and authoritative enforcement points.
- Owner, Admin, group, project, module, portal and mobile roles are represented in the registry.
- No protected action depends only on UI visibility or a role-name shortcut.
- Explicit deny, SoD, delegation, temporary access and field policy operate in APIs and derived systems.
- Support, impersonation and break-glass sessions are production-ready and auditable.
- Revocation propagates within the agreed SLA.
- Authorization diagnostics and access reviews are usable by authorized administrators.
- Negative isolation and confidentiality tests pass across web, API, search, export, portal and mobile.
- No unresolved critical authorization, privacy or cross-company leakage defect remains.

Final architectural position

ConstructionOS authorization is a deny-by-default, capability-based and context-aware platform. It evaluates company ownership, active scope, project relationships, record sensitivity, field policy, temporary authority, device state and separation of duties for every protected action.

Appendix A - Capability Examples

Capability key	Domain	Note
projects.project.view	Projects	Example - final naming confirmed in machine registry
projects.project.edit	Projects	Example - final naming confirmed in machine registry
projects.participant.manage	Projects	Example - final naming confirmed in machine registry
projects.project.archive	Projects	Example - final naming confirmed in machine registry
tasks.task.create	Tasks	Example - final naming confirmed in machine registry

Capability key	Domain	Note
tasks.task.assign	Tasks	Example - final naming confirmed in machine registry
tasks.task.complete	Tasks	Example - final naming confirmed in machine registry
tasks.task.reopen	Tasks	Example - final naming confirmed in machine registry
documents.document.view	Documents	Example - final naming confirmed in machine registry
documents.revision.upload	Documents	Example - final naming confirmed in machine registry
documents.revision.approve	Documents	Example - final naming confirmed in machine registry
documents.revision.publish	Documents	Example - final naming confirmed in machine registry
documents.document.export	Documents	Example - final naming confirmed in machine registry
finance.journal.create	Finance	Example - final naming confirmed in machine registry
finance.journal.approve	Finance	Example - final naming confirmed in machine registry
finance.journal.post	Finance	Example - final naming confirmed in machine registry
finance.payment.prepare	Finance	Example - final naming confirmed in machine registry
finance.payment.approve	Finance	Example - final naming confirmed in machine registry
finance.payment.execute	Finance	Example - final naming confirmed in machine registry
finance.period.close	Finance	Example - final naming confirmed in machine registry
procurement.requisition.create	Procurement	Example - final naming confirmed in machine registry
procurement.rfq.issue	Procurement	Example - final naming confirmed in machine registry
procurement.quotation.view_confidential	Procurement	Example - final naming confirmed in machine registry
procurement.award.recommend	Procurement	Example - final naming confirmed in machine registry
procurement.purchase_order.issue	Procurement	Example - final naming confirmed in machine registry
contracts.contract.draft	Contracts	Example - final naming confirmed in machine registry
contracts.contract.review	Contracts	Example - final naming confirmed in machine registry
contracts.contract.issue	Contracts	Example - final naming confirmed in machine registry
contracts.amendment.create	Contracts	Example - final naming confirmed in machine registry

Capability key	Domain	Note
hr.employee.view	HR	Example - final naming confirmed in machine registry
hr.employee.edit	HR	Example - final naming confirmed in machine registry
hr.compensation.view	HR	Example - final naming confirmed in machine registry
hr.payroll.calculate	HR	Example - final naming confirmed in machine registry
hr.payroll.finalize	HR	Example - final naming confirmed in machine registry
qa/qc.inspection.execute	QA/QC	Example - final naming confirmed in machine registry
qa/qc.inspection.accept	QA/QC	Example - final naming confirmed in machine registry
qa/qc.ncr.close	QA/QC	Example - final naming confirmed in machine registry
qa/qc.handover.accept	QA/QC	Example - final naming confirmed in machine registry
hse.incident.report	HSE	Example - final naming confirmed in machine registry
hse.incident.classify	HSE	Example - final naming confirmed in machine registry
hse.stop_work.issue	HSE	Example - final naming confirmed in machine registry
hse.stop_work.release	HSE	Example - final naming confirmed in machine registry
workflow.definition.design	Workflow	Example - final naming confirmed in machine registry
workflow.definition.publish	Workflow	Example - final naming confirmed in machine registry
workflow.work_item.decide	Workflow	Example - final naming confirmed in machine registry
workflow.override.review	Workflow	Example - final naming confirmed in machine registry
platform.company.verify	Platform	Example - final naming confirmed in machine registry
platform.support_session.enter	Platform	Example - final naming confirmed in machine registry
platform.owner.recover	Platform	Example - final naming confirmed in machine registry
platform.company.delete_execute	Platform	Example - final naming confirmed in machine registry

Appendix B - Standard Role Catalogue

Role template	Default scope	Notes
Platform Super Admin	Configured by role family	Versioned system template; company may clone

Role template	Default scope	Notes
		within guardrails
Company Operations Admin	Configured by role family	Versioned system template; company may clone within guardrails
Application Reviewer	Configured by role family	Versioned system template; company may clone within guardrails
Billing Admin	Configured by role family	Versioned system template; company may clone within guardrails
Support Admin	Configured by role family	Versioned system template; company may clone within guardrails
Security / SRE Admin	Configured by role family	Versioned system template; company may clone within guardrails
Parent Company Owner	Configured by role family	Versioned system template; company may clone within guardrails
Company Owner	Configured by role family	Versioned system template; company may clone within guardrails
Group Admin	Configured by role family	Versioned system template; company may clone within guardrails
Company Admin	Configured by role family	Versioned system template; company may clone within guardrails
Executive / CEO	Configured by role family	Versioned system template; company may clone within guardrails
Department Manager	Configured by role family	Versioned system template; company may clone within guardrails
Team Manager	Configured by role family	Versioned system template; company may clone within guardrails
Project Director	Configured by role family	Versioned system template; company may clone within guardrails
Project Manager	Configured by role family	Versioned system template; company may clone within guardrails
Site Manager	Configured by role family	Versioned system template; company may clone within guardrails
Project Controls Manager	Configured by role family	Versioned system template; company may clone within guardrails
Commercial Manager	Configured by role family	Versioned system template; company may clone within guardrails
Design Manager	Configured by role family	Versioned system template; company may clone within guardrails
BIM Manager	Configured by role family	Versioned system template; company may clone within guardrails
QA/QC Manager	Configured by role family	Versioned system template; company may clone within guardrails
HSE Manager	Configured by role family	Versioned system template; company may clone within guardrails
Document Controller	Configured by role family	Versioned system template; company may clone within guardrails
Procurement Manager	Configured by role family	Versioned system template; company may clone within guardrails
Warehouse Manager	Configured by role family	Versioned system template; company may clone

Role template	Default scope	Notes
		within guardrails
Asset Manager	Configured by role family	Versioned system template; company may clone within guardrails
Finance Director	Configured by role family	Versioned system template; company may clone within guardrails
Accountant	Configured by role family	Versioned system template; company may clone within guardrails
Treasury	Configured by role family	Versioned system template; company may clone within guardrails
Contracts Manager	Configured by role family	Versioned system template; company may clone within guardrails
General Counsel	Configured by role family	Versioned system template; company may clone within guardrails
HR Manager	Configured by role family	Versioned system template; company may clone within guardrails
Payroll Manager	Configured by role family	Versioned system template; company may clone within guardrails
Sales Manager	Configured by role family	Versioned system template; company may clone within guardrails
Report Author	Configured by role family	Versioned system template; company may clone within guardrails
Workflow Administrator	Configured by role family	Versioned system template; company may clone within guardrails
Workflow Designer	Configured by role family	Versioned system template; company may clone within guardrails
Client Organization Admin	Configured by role family	Versioned system template; company may clone within guardrails
Supplier Organization Admin	Configured by role family	Versioned system template; company may clone within guardrails
Employee Self-Service	Configured by role family	Versioned system template; company may clone within guardrails
Guest / Required Reader	Configured by role family	Versioned system template; company may clone within guardrails